

Purpose of this document

A practical legal-by-design guide for the Maal MVP: what Saudi legal/regulatory areas matter, what risk they create for the product, and exactly how the team can address each risk in the architecture and demo.

Prepared for the Maal Team | September 2026

1. Executive Summary

Maal is designed as an AI-assisted regulatory compliance decision-support system. Its legal design should therefore focus on four questions: (1) what data it processes, (2) how it uses AI and produces recommendations, (3) how it protects regulatory and organizational information, and (4) how it preserves evidence, accountability and human oversight.

Core legal position

Maal should not present itself as an autonomous legal decision-maker. It should analyze regulatory changes, identify potential impacts, and recommend actions; an authorized human remains responsible for reviewing and approving high-risk or legally significant outcomes.

What the team should implement

- Use an Approved Sources Registry so regulatory analysis starts from official/authorized sources.
- Store the source, version, publication/effective dates and exact clause/span behind every AI result.
- Use data minimization: do not send personal or confidential data to an LLM unless it is necessary and appropriately governed.
- Route high-risk or low-confidence recommendations to a human reviewer before they become compliance actions.
- Keep an audit trail: source → changed clause → obligation → impact → risk → recommendation → reviewer decision.
- For the MVP, use synthetic/non-personal data and a controlled regulatory example to reduce privacy and confidentiality risk.
- Treat Saudi AI Ethics Principles as a governance baseline and verify the specific legal applicability of PDPL/NCA controls to the deploying entity.

Important distinction

Not every document discussed in this report has the same legal status. The PDPL and its regulations are binding legal instruments; NCA controls may apply according to the organization's scope; SDAIA AI Ethics Principles provide an ethical/governance framework. The team should not describe an ethical principle or a control as a universally applicable law without checking scope.

2. Legal & Regulatory Framework at a Glance

Area	Why it matters to Maal	Main risk	Maal response	Priority
Personal data — PDPL	Maal may process employee/user or other personal data.	Unauthorized use, excess collection, inappropriate retention.	Data minimization, access control, purpose limitation, retention/deletion rules.	HIGH
Cross-border data transfer	External LLM/API providers may process data outside KSA.	Transfer may trigger PDPL conditions and safeguards.	Prefer KSA processing for sensitive use cases; minimize data; assess transfer and safeguards.	HIGH
AI ethics & governance	AI generates risk classifications and recommendations.	Bias, opacity, unsafe or unaccountable decisions.	Human review, confidence thresholds, traceability, testing, monitoring.	HIGH
Cybersecurity	Maal handles regulatory and potentially confidential organizational data.	Unauthorized access, leakage, tampering.	RBAC, encryption, secure APIs, audit logs, secure deployment.	HIGH
Official-source governance	Wrong or outdated sources can produce wrong compliance advice.	False compliance recommendation.	Approved-source registry, versioning, source citations, freshness checks.	HIGH
Copyright / content use	Maal may store, retrieve and display regulatory documents.	Improper reproduction/use of protected content.	Source links/citations; controlled excerpts; review reuse terms for non-official content.	MEDIUM

3. Personal Data Protection Law (PDPL)

The PDPL is the main privacy law to consider if Maal processes personal data. SDAIA's knowledge center provides the PDPL, its Implementing Regulation, the Regulation on Personal Data Transfer Outside the Kingdom, and practical guidance including minimum personal-data determination and anonymization/pseudonymisation.

Official SDAIA Knowledge Center: <https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/>

What this means for Maal

- Define the purpose of each category of personal data before collecting or processing it.
- Collect only what is necessary for that purpose. SDAIA's minimum-data guidance specifically emphasizes relevance, necessity, limited retention and deletion when the purpose ends.
- Separate regulatory content from user identity data. A regulation-analysis task often does not need names, employee IDs or other identifiers.
- Apply role-based access so users only see the compliance cases and organizational information they are authorized to access.
- Define retention/deletion rules for uploaded documents, extracted data, AI prompts and logs.

Maal design rule

If a piece of personal data does not change the regulatory analysis, do not send it to the AI model.

4. External LLMs & Cross-Border Data

A key architectural question is whether an external LLM/API receives personal data or confidential organizational information. The PDPL contains rules for transferring personal data outside the Kingdom, and the dedicated transfer regulation addresses safeguards, minimum data, risks and appropriate protections.

SDAIA — PDPL: <https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL>

SDAIA — Regulation on Personal Data Transfer Outside the Kingdom:
<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/RegulationonPersonalDataTransferOutsidetheKingdom>

Recommended MVP approach

- 1. Use synthetic/non-personal data for the hackathon demo.
- 2. Keep the regulatory documents and analysis dataset free of unnecessary personal identifiers.
- 3. If an external LLM is used, send only the minimum context required for the task.
- 4. For a production deployment, conduct a data-flow and transfer assessment before sending personal data to an external provider.
- 5. For sensitive enterprise deployment, consider a KSA-hosted or otherwise appropriately governed model/processing environment.

5. AI Ethics & Human Oversight

SDAIA's AI Ethics Principles provide a useful governance baseline for Maal. The framework covers responsible AI and emphasizes principles including integrity and fairness, privacy and security, reliability and safety, transparency and interpretability, and accountability and responsibility. SDAIA also provides an AI Ethics Self-Assessment service.

SDAIA — AI Ethics Principles: <https://sdaia.gov.sa/en/SDAIA/about/Documents/ai-principles.pdf>

SDAIA — AI Ethics Self-Assessment: <https://dgp.sdaia.gov.sa/wps/portal/pdp/services/AIEthicsAssessment>

Translate the principles into Maal features

Principle	Risk in Maal	Concrete feature
Transparency & Interpretability	User cannot understand why an action was recommended.	Show changed clause, evidence, reasoning summary and citation.
Accountability & Responsibility	AI output is treated as the final legal decision.	Human approval for high-risk/low-confidence cases; reviewer identity + timestamp.
Reliability & Safety	LLM hallucinates a requirement or misreads a document.	RAG, source grounding, confidence score, validation and evaluation set.
Privacy & Security	Sensitive data enters prompts or logs.	Minimization, access controls, secure logging, controlled retention.
Fairness / Integrity	Risk classification behaves inconsistently across cases.	Test on representative labeled cases and monitor error patterns.

6. Cybersecurity & Sensitive Industrial Context

Because Maal is aimed at energy/industrial environments, cybersecurity is not an optional add-on. The NCA publishes the Essential Cybersecurity Controls (ECC 2-2024), Data Cybersecurity Controls (DCC-1:2022), Cloud Cybersecurity Controls (CCC-2:2024), and Operational Technology Cybersecurity Controls (OTCC-1:2022). Applicability depends on the organization and system scope.

NCA — Essential Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/ecc/>

NCA — Data Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/dcc/>

NCA — Cloud Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/ccc/>

NCA — Operational Technology Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/otcc/>

Maal security baseline

- Role-Based Access Control (RBAC) for compliance officers, reviewers and administrators.
- Encryption in transit and at rest.
- Authentication and secure API access.
- Audit logging for document uploads, AI analysis, recommendations and approvals.
- Input validation and protection against prompt injection or malicious document content.
- Separate development/demo data from production or confidential enterprise data.
- If the product later connects to industrial/OT systems, perform a dedicated OT security assessment rather than assuming normal web-app controls are sufficient.

7. Regulatory Sources, Evidence & Copyright

Maal's core legal risk is not only privacy; it is also the risk of analyzing the wrong version or an unofficial copy of a regulation. The technical benchmark already recommends official-source ingestion, versioning and source citations. This should become a governance rule.

Approved Sources Registry

Every source used by Maal should have an authority, URL, jurisdiction, source type, last-checked date and approval status. The agent should prioritize approved official sources and flag unverified material.

Copyright / reuse

Saudi Arabia's Copyright Law protects qualifying works and regulates authors' economic rights. It also states that official documents such as laws, judicial judgments, administrative decisions and international agreements are excluded from copyright protection, subject to rules governing circulation. The same law contains rules for protected works and lawful quotation with attribution.

Bureau of Experts — Copyright Law: <https://laws.boe.gov.sa/BoeLaws/Laws/LawDetails/67d159e6-ee98-4efc-a2ee-a9a700f17083/1>

Practical recommendation: for the MVP, keep the source URL, document metadata and exact relevant excerpt/citation rather than building a large redistribution library. For third-party commentary, proprietary databases or vendor content, check the applicable license/terms before storing or redistributing the material.

8. AI Recommendation, Liability & Human-in-the-Loop

The product should be positioned as compliance decision support, not as a replacement for legal counsel or the organization's authorized compliance function. This is especially important because the technical benchmark found evidence that LLM-based change analysis can be sensitive to document format and ambiguous/context-dependent changes.

Recommended decision policy

Case	AI action	Human action	Final status
High confidence + low risk	Generate recommendation with evidence.	Review according to organization policy.	Can proceed after normal approval.
Low confidence	Flag uncertainty and show evidence.	Mandatory review/edit.	No automatic action.
High risk / legal impact	Analyze and recommend only.	Mandatory authorized approval.	Human-approved action only.
No authoritative source	Do not produce a definitive	User finds/validates source.	Blocked / needs evidence.

	compliance conclusion.		
--	------------------------	--	--

Recommended product wording

“Maal provides AI-assisted regulatory analysis and compliance recommendations. Final compliance decisions and actions remain subject to authorized human review and organizational policy.”

9. Traceability — The Legal + Technical Bridge

Traceability should be treated as both a technical and governance requirement. Every recommendation should be explainable through a chain of evidence rather than appearing as an unsupported LLM answer.

Official Source → Document Version → Changed Clause → Obligation → Impact → Risk → Recommendation → Human Review → Final Decision

Minimum audit record: source URL, issuer, document/version, publication/effective date, clause/span, AI analysis timestamp, model/system version, confidence, recommendation, reviewer, reviewer edits, approval/rejection, and final decision.

10. Legal-by-Design MVP Checklist

Area	Maal implementation	Priority
Source governance	Approved official sources + source metadata + versioning	MUST
Evidence	Every recommendation has citation and supporting clause/span	MUST
Human oversight	High-risk/low-confidence queue + reviewer approval	MUST
Privacy	Synthetic/non-personal demo data + data minimization	MUST
Security	RBAC + authentication + audit logs	MUST
LLM governance	Confidence/uncertainty handling + no unsupported legal conclusion	MUST
Data transfer	Document whether any external API receives data; avoid personal/confidential data in MVP	MUST
Retention	Define what is stored and when it is deleted	SHOULD
Copyright	Use official sources and controlled excerpts; verify terms for third-party content	SHOULD
Production readiness	Formal legal/privacy/security assessment before enterprise deployment	FUTURE

One-minute summary

“From the legal side, Maal should be designed as a governed compliance assistant, not an autonomous legal decision-maker. The main Saudi considerations are PDPL and cross-border data when personal data is involved, SDAIA AI ethics and governance, and NCA cybersecurity controls for protecting regulatory and industrial information. Our implementation is therefore: official sources only, data minimization, RAG with citations, human approval for high-risk or low-confidence cases, and a full audit trail from the regulatory clause to the final recommendation. For the hackathon MVP we can use synthetic data and demonstrate this governance model without exposing real personal or confidential information.”

11. Final Conclusion

The strongest legal positioning for Maal is not to claim that the AI itself guarantees compliance. The stronger proposition is that Maal creates a controlled, evidence-based and human-governed workflow for regulatory change management. This directly complements the technical research: RAG provides grounding, the agentic workflow provides automation, and human review + traceability provide governance.

This document is a product-design and research guide for the hackathon, not legal advice. Before commercial deployment, the final data flows, contracts, source licenses, security scope and regulatory applicability should be reviewed by qualified legal/privacy/security professionals.

References — Official / Primary Sources

SDAIA — PDPL Knowledge Center: <https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/>

SDAIA — Personal Data Protection Law:

<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL>

SDAIA — Implementing Regulation of PDPL:

<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL2>

SDAIA — Regulation on Personal Data Transfer Outside the Kingdom:

<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/RegulationonPersonalDataTransferOutsidetheKingdom>

SDAIA — Minimum Personal Data Determination Guideline:

<https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/MinimumPersonalDataDeterminationGuideline>

SDAIA — AI Ethics Principles: <https://sdaia.gov.sa/en/SDAIA/about/Documents/ai-principles.pdf>

SDAIA — AI Ethics Self-Assessment: <https://dgp.sdaia.gov.sa/wps/portal/pdp/services/AIEthicsAssessment>

NCA — Essential Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/ecc/>

NCA — Data Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/dcc/>

NCA — Cloud Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/cccl/>

NCA — Operational Technology Cybersecurity Controls: <https://nca.gov.sa/en/regulatory-documents/controls-list/otcc/>

Bureau of Experts — Copyright Law: <https://laws.boe.gov.sa/BoeLaws/Laws/LawDetails/67d159e6-ee98-4efc-a2ee-a9a700f17083/1>